

Étape 3 : Analyse du Serveur C2

Objectif : Comprendre comment le ransomware communique avec son serveur Command & Control.

Objectifs de l'Étape

À la fin de cette étape, vous devez :

-  Identifier les endpoints de l'API C2
 -  Comprendre quelles données sont exfiltrées
 -  Analyser le protocole de communication
 -  Créer un schéma du fonctionnement C2
 -  Documenter les IOCs réseau
-

Fichiers Fournis

```
Etape3_AnalyseC2/  
├─ README.md           # Ce fichier  
├─ network_capture.log # Logs réseau déjà capturés  
└─ SOLUTIONS.md        # Solutions
```

Instructions

1. Analyse du Code Source

1.1 Identifier la Configuration C2

Ouvrez le code source du ransomware :

```
cd Etape3_AnalyseC2/  
  
# Chercher la configuration du serveur C2
```

 **Question 1 :** Quelle est l'adresse complète du serveur C2 ?

 **Question 2 :** Sur quel port écoute le serveur ? (indice : URL complète)

1.2 Identifier les Endpoints

 **Question 3 :** Listez tous les endpoints trouvés :

1.3 Analyser la Fonction `send_to_c2`

Lisez la fonction `send_to_c2()` dans le code source :

```
grep -A20 "int send_to_c2" ../Etape1_AnalyseStatique/ransomware.c
```

 **Question 4** : Quel outil système est utilisé pour envoyer les requêtes ?

 **Question 5** : Quel est le type de requête HTTP utilisé ?

 **Question 6** : Quel format de données est envoyé ?

2. Analyse des Communications

2.1 Fonction `register_victim`

Lisez la fonction `register_victim()` :

```
grep -A10 "void register_victim" ../Etape1_AnalyseStatique/ransomware.c
```

 **Question 7** : Quelles informations sont envoyées lors de l'enregistrement ?

 **Question 8** : Reconstituez le JSON envoyé (exemple) :

```
{
  "victim_id": "...",
  "hostname": "...",
  "timestamp": ...
}
```

2.2 Fonction `send_key_to_c2`

Lisez la fonction `send_key_to_c2()` :

```
grep -A10 "void send_key_to_c2" ../Etape1_AnalyseStatique/ransomware.c
```

 **Question 9** : Quelles informations sont envoyées ?

 **Question 10** : Pourquoi l'attaquant a-t-il besoin de récupérer la clé ?

3. Analyse des Logs Réseau

3.1 Consulter les Logs Fournis

Un fichier `network_capture.log` contient une capture réseau déjà effectuée.

```
cat network_capture.log
```



Question 11 : Combien de requêtes HTTP voyez-vous ?

3.2 Extraire les Requêtes POST

```
grep ?
```



Question 12 : Vers quels endpoints les requêtes POST sont-elles envoyées ?

3.3 Analyser le Contenu JSON

```
grep -A3 "Content-Type: application/json" network_capture.log
```



Question 13 : Copiez un exemple de requête JSON complète :

4. Capture Réseau en Temps Réel (Optionnel)

4.1 Installer le Serveur C2 (si pas encore fait)

Le serveur C2 sera installé à l'Étape 5, mais vous pouvez le lancer maintenant :

```
# Voir l'Étape 5 pour les instructions, faire le lancement du serveur et  
revenir ici
```

4.2 Capturer le Trafic avec tcpdump

```
# Dans un terminal  
sudo tcpdump -i lo -w capture.pcap port 5000  
  
# Dans un autre terminal  
cd ../Etape1_AnalyseStatique/  
./ransomware ./test_files
```

```
# Arrêter tcpdump (Ctrl+C)
```

4.3 Analyser la Capture

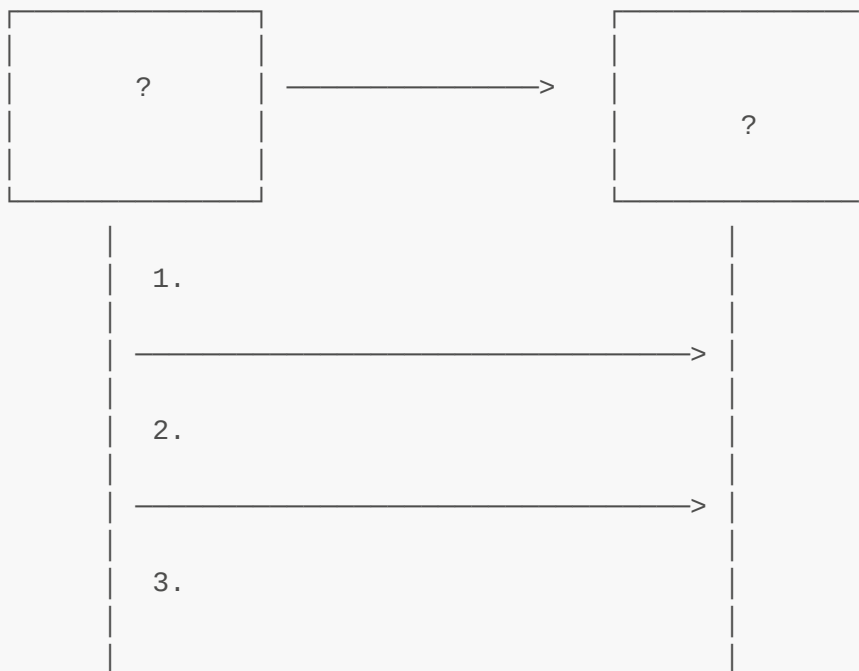
```
# Voir les strings dans la capture
strings capture.pcap | grep -E "POST|GET|HTTP"

# Extraire les requêtes
strings capture.pcap | grep -A5 "POST"
```

5. Schéma de Communication

5.1 Créer un Schéma Visuel

Dessinez (sur papier ou avec un outil) le schéma de communication :



 **Question 14** : Complétez ce schéma

5.2 Timeline de l'Attaque

Remettez dans l'ordre chronologique :

 **Question 15** : Numérotez les étapes :

- ☐ Chiffrement des fichiers
 - ☐ Génération du victim_id
 - ☐ Envoi de la clé au C2
 - ☐ Enregistrement de la victime
 - ☐ Affichage de la note de rançon
 - ☐ Scan du répertoire cible
-

6. Indicateurs de Compromission Réseau

6.1 IOCs Réseau

Créez un fichier `network_iocs.txt` :

```
cat > network_iocs.txt << 'EOF'
# Network IOCs - Ransomware

## C2 Infrastructure
IP/Domain: localhost (ou IP réelle si différent)
Port: 5000
Protocol: HTTP (non chiffré)

## Endpoints
POST /api/register
POST /api/key

## User-Agent
curl/7.x.x (ou autre)

## Données Exfiltrées
- Victim ID (format: VICTIM_hostname_timestamp)
- Hostname de la victime
- Clé de chiffrement (19 bytes)
- Timestamp de l'infection

## Détection Réseau
- POST vers /api/register
- POST vers /api/key
- Content-Type: application/json
- Taille des requêtes: ~100-200 bytes
EOF
```

7. Vulnérabilités de Communication

 **Question 16** : Identifiez 3 faiblesses dans la communication C2 :

 **Question 17** : Comment un administrateur réseau pourrait-il détecter ce trafic ?

- ☐ Règle firewall

- ☐ Analyse du trafic HTTP
 - ☐ IDS/IPS (Snort, Suricata)
 - ☐ Proxy avec inspection SSL
 - ☐ Autre : ?
-



Livrables de l'Étape 3

À remettre :

- ☒ Fichier `network_iocs.txt` complet
 - ☒ Schéma de communication (dessin, photo, ou diagramme)
 - ☒ Réponses aux 17 questions
 - ☒ Exemple de requête JSON capturée
-



Prochaine Étape

Maintenant que vous comprenez le fonctionnement du C2, passez à **l'Étape 4 : Recouvrement de Données** pour créer votre outil de déchiffrement !

Bonne analyse ! 🌐🔍